



## Raport ekspercki

Badanie bezpieczeństwa sieci od środka

5

Wykryte urządzenia

10

Otwarte porty

14

Ustalenia wymagające działania

5

Luki w pokryciu badania

Sonda

Sonda demonstracyjna

Identyfikator badania

PROBKA-0000-0000-0000-DEMO

Data wykonania badania

2026-09-18 09:12:44

Przebieg badania

zakończone

Adres sondy w badanej sieci

192.0.2.250

Raport odebrany

2026-10-04 15:10:55 UTC

Najwyższe stwierdzone ryzyko: **Krytyczne**

Najbardziej narażone urządzenia: 192.0.2.30 (8 ustaleń), 192.0.2.20 (2 ustalenia), 192.0.2.1 (1 ustalenie)

# 1. Podsumowanie badania

Ocena ryzyka wynikająca z całości badania.

Badanie wykazało stan krytyczny. W sieci wykryto 5 urządzeń, z czego 4 odpowiedziały na skanowanie portów i na każdym z nich stwierdzono co najmniej jeden otwarty port — łącznie 10 otwartych usług. Sformułowano 14 ustaleń wymagających działania: 2 o wadze krytycznej, 5 o wadze wysokiej i 7 o wadze średniej. Oba ustalenia krytyczne dotyczą hosta 192.0.2.30, na którym potwierdzono zdalne wykonanie kodu przez usługę bazy danych PostgreSQL oraz podatność SSL POODLE na porcie 8443. Ustalenia te wymagają natychmiastowej reakcji, ponieważ host łączy w jednym punkcie dostęp do danych osobowych i kart płatniczych z potwierdzoną możliwością wykonania kodu.

Ocena ryzyka biznesowego jest wysoka i wynika z kumulacji ekspozycji danych oraz podatności dających kontrolę nad infrastrukturą. Na 192.0.2.30 stwierdzono konto bazy MySQL bez hasła oraz dane wrażliwe (PESEL, numer karty kredytowej) dostępne w bazie, a na 192.0.2.20 aktywny jest Telnet przesyłający poświadczenia otwartym tekstem. Brak blokady Gratuitous ARP umożliwia przechwycenie ruchu w segmencie, a filtrowanie ruchu wychodzącego przepuszcza na zewnątrz porty 23, 445 i 3389. Część obszarów nie została zbadana, co ogranicza pełność oceny i zostaje wskazane w dalszej części raportu.

## 2. Ustalenia według wagi

Wszystko, co badanie wykazało, zebrane w jednym miejscu i uszeregowane od najpoważniejszego. Wagi wynikają z tego, co stwierdziły testy - ustalenie, którego test nie zdołał potwierdzić, jest oceniane niżej niż potwierdzone.

**2**

Krytyczne

**5**

Wysokie

**7**

Średnie

**0**

Informacyjne

| WAGA      | GDZIE                                             | USTALENIE                                                                                                                                                                                                                                                                                                                                                                                                                |
|-----------|---------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Krytyczne | 192.0.2.30<br>ssl-poodle · port 8443              | SSL POODLE information leak<br>CVE-2014-3566                                                                                                                                                                                                                                                                                                                                                                             |
| Krytyczne | 192.0.2.30<br>PostgreSQL                          | Potwierdzone zdalne wykonanie kodu na bazie danych (RCE)<br>Sonda wykonała polecenie systemowe przez usługę bazy danych.                                                                                                                                                                                                                                                                                                 |
| Wysokie   | 192.0.2.30<br>http-slowloris-check ·<br>port 8443 | Slowloris DOS attack<br>CVE-2007-6750                                                                                                                                                                                                                                                                                                                                                                                    |
| Wysokie   | 192.0.2.30<br>MySQL                               | Konto bazy danych bez hasła<br>root                                                                                                                                                                                                                                                                                                                                                                                      |
| Wysokie   | 192.0.2.30<br>MySQL                               | Dane wrażliwe dostępne w bazie danych<br>PESEL w crm.klienci; KARTA KREDYTOWA w crm.platnosci                                                                                                                                                                                                                                                                                                                            |
| Wysokie   | 192.0.2.20<br>23/TCP                              | Telnet dostępny w sieci<br>Protokół przesyła hasła otwartym tekstem.                                                                                                                                                                                                                                                                                                                                                     |
| Wysokie   | cała sieć                                         | Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać.                                                                                                                                                                                                                                                                                                                                               |
| Średnie   | 192.0.2.30                                        | Serwer WWW ujawnił ścieżki wymagające weryfikacji<br>Wykryte podczas fuzzingu katalogów; część może być fałszywa - wymaga ręcznego potwierdzenia. <a href="https://192.0.2.30:8443/.git/config">https://192.0.2.30:8443/.git/config</a> ,<br><a href="https://192.0.2.30:8443/backup.sql">https://192.0.2.30:8443/backup.sql</a> , <a href="https://192.0.2.30:8443/phpinfo.php">https://192.0.2.30:8443/phpinfo.php</a> |
| Średnie   | 192.0.2.20<br>port 80                             | Panel kamery dostępny po nieszyfrowanym HTTP<br>Wymuś HTTPS i ogranicz dostęp do sieci zarządzającej.                                                                                                                                                                                                                                                                                                                    |
| Średnie   | 192.0.2.1<br>port 53                              | Znane podatności w dnsmasq 2.80 (3 CVE, najwyższy CVSS 8.1)<br>CVE-2021-3448, CVE-2020-25681, CVE-2020-25684<br>Dopasowanie po numerze wersji - wymaga potwierdzenia, czy podatny kod jest faktycznie używany.                                                                                                                                                                                                           |
| Średnie   | 192.0.2.10<br>445/TCP                             | Udostępnianie plików SMB dostępny w sieci<br>Dostęp do plików i klasyczny cel ataków w sieci lokalnej.                                                                                                                                                                                                                                                                                                                   |
| Średnie   | 192.0.2.30<br>3306/TCP                            | Baza danych MySQL dostępny w sieci<br>Baza danych nasłuchująca w sieci.                                                                                                                                                                                                                                                                                                                                                  |

| WAGA    | GDZIE                 | USTALENIE                                      |
|---------|-----------------------|------------------------------------------------|
| Średnie | 192.0.2.30<br>502/TCP | Modbus dostępny w sieci                        |
| Średnie | cała sieć             | Porty przepuszczane na zewnątrz: 23, 445, 3389 |

### Luki w pokryciu badania (5)

Poniższe testy nie dostarczyły wyniku. Tych obszarów badanie nie sprawdziło, więc nie można ich uznać ani za bezpieczne, ani za zagrożone.

- 192.0.2.40 — Skanowanie portów: test nie powiódł się na tym urządzeniu
- Sieci bezprzewodowe: test zablokowany przez zakres lub politykę badania
- Zatrutowanie rozgłoszeń — sonda nie przekazała wyniku
- Wycieki z katalogu LDAP — test nie wykonał się
- Bezpieczeństwo sieci bezprzewodowej — Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył.

Ustalenia krytyczne dotyczą wyłącznie hosta 192.0.2.30. Podatność SSL POODLE (CVE-2014-3566) na porcie 8443 pozwala na ujawnienie informacji z sesji szyfrowanej, co przy dostępie do danych uwierzytelniających stanowi bezpośrednie zagrożenie dla poufności. Drugie ustalenie krytyczne to potwierdzone zdalne wykonanie kodu na bazie PostgreSQL — sonda wykonała polecenie systemowe przez usługę bazy danych, co oznacza przejęcie kontroli nad hostem i pełny dostęp do danych na nim przetwarzanych.

Ustalenia wysokie obejmują pięć pozycji. Na 192.0.2.30 wykryto podatność na atak Slowloris (CVE-2007-6750) na porcie 8443, konto bazy MySQL bez hasła (root) oraz dostęp do danych wrażliwych w bazie (PESEL w crm.klienci, numer karty kredytowej w crm.platnosci). Na 192.0.2.20 stwierdzono otwarty Telnet, który przesyła hasła otwartym tekstem, co umożliwia ich przechwycenie przez dowolny podmiot w ścieżce transmisji. Piąte ustalenie wysokie dotyczy braku blokady Gratuitous ARP — mechanizm ten pozwala przekierować ruch w segmencie i prowadzić podsłuch oraz atak typu man-in-the-middle.

Ustalenia średnie obejmują ujawnione przez serwer WWW na 192.0.2.30 ścieżki wymagające weryfikacji (.git/config, backup.sql, phpinfo.php — część może być fałszywa), panel kamery na 192.0.2.20 udostępniony po nieszyfrowanym HTTP na porcie 80, znane podatności w dnsmasq 2.80 na 192.0.2.1 (3 CVE, najwyższy CVSS 8.1), udostępnianie SMB na 192.0.2.10, eksponowanie MySQL na 192.0.2.30, usługę Modbus na 192.0.2.30 oraz przepuszczanie na zewnątrz portów 23, 445 i 3389. Ustaleń o wadze informacyjnej nie odnotowano.

Pokrycie badania jest niepełne. Skanowanie portów na 192.0.2.40 nie powiodło się, a moduł badania nie wykonał się poprawnie. Nie wykonano testów wycieków z katalogu LDAP, nie odebrano wyniku testu zatrutowania rozgłoszeń, a testy sieci bezprzewodowych zostały zablokowane przez zakres lub politykę badania oraz przez brak trybu monitora. Obszarów tych nie można uznać za bezpieczne.

### 3. Wykryte urządzenia

Przegląd segmentu sieci i lista wszystkich urządzeń, które się w nim odezwały. Urządzenie, które odpowiedziało przy wykrywaniu, ale zamilkło przy skanowaniu portów, jest odnotowane osobno.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

| ADRES      | ADRES SPRZĘTOWY   | PRODUCENT I MODEL                          | STAN                                                |
|------------|-------------------|--------------------------------------------|-----------------------------------------------------|
| 192.0.2.1  | 02:00:5e:00:53:01 | Acme Networks GW-200<br>Linux 4.x (router) | 3 otwarte porty                                     |
| 192.0.2.10 | 02:00:5e:00:53:0a | NorthStore NAS-4B<br>Linux (NAS)           | 2 otwarte porty                                     |
| 192.0.2.20 | 02:00:5e:00:53:14 | Visinet IP-Cam 3<br>Embedded Linux         | 2 otwarte porty                                     |
| 192.0.2.30 | 02:00:5e:00:53:1e | Generic Server Co.<br>CentOS 7             | 3 otwarte porty                                     |
| 192.0.2.40 | —                 | nieznany                                   | skanowanie nieudane<br>test przekroczył limit czasu |

Wykrytych urządzeń: **5**, odpowiedziało na skanowanie portów: **4**.

W badanym segmencie wykryto 5 urządzeń, z których 4 odpowiedziały na skanowanie portów i na 4 stwierdzono co najmniej jeden otwarty port. Zidentyfikowano router Acme Networks GW-200 (192.0.2.1), serwer plików NorthStore NAS-4B (192.0.2.10), kamerę Visinet IP-Cam 3 (192.0.2.20) oraz serwer Generic Server Co. z systemem CentOS 7 (192.0.2.30). Skanowanie portów na 192.0.2.40 nie powiodło się — test przekroczył limit czasu i wyniki dla tego urządzenia nie zostały uzyskane.

Brak identyfikacji 192.0.2.40 oznacza lukę w rozpoznaniu sieci; urządzenie odpowiada w warstwie wykrywania, lecz nie ustalono jego charakteru ani ekspozycji usług. Na pozostałych hostach rozkład ekspozycji jest nierównomierny: największe nagromadzenie usług dotyczy 192.0.2.30, na którym jednocześnie skoncentrowane są wszystkie ustalenia o wadze krytycznej i większość wysokich.

## 4. Usługi dostępne w sieci

Sprawdzenie, co nasłuchuje na każdym wykrytym urządzeniu i w jakiej wersji. Wynik zostaje zachowany w pełnej postaci, nie w formie skrótu.

Test nie powiódł się na 1 urządzeniu: 192.0.2.40. Wyniki poniżej dotyczą wyłącznie urządzeń, które udało się sprawdzić.

| URZĄDZENIE | PORT     | USŁUGA       | WERSJA ROZPOZNANA PRZEZ SONDĘ |
|------------|----------|--------------|-------------------------------|
| 192.0.2.1  | 53/TCP   | domain       | dnsmasq 2.80                  |
| 192.0.2.1  | 80/TCP   | http         | lighttpd 1.4.59               |
| 192.0.2.1  | 443/TCP  | https        | lighttpd 1.4.59               |
| 192.0.2.10 | 445/TCP  | microsoft-ds | Samba smbd 4.15.13            |
| 192.0.2.10 | 5000/TCP | http         | Synology DSM httpd            |
| 192.0.2.20 | 23/TCP   | telnet       | nie ustalono                  |
| 192.0.2.20 | 554/TCP  | rtsp         | nie ustalono                  |
| 192.0.2.30 | 22/TCP   | ssh          | OpenSSH 7.4                   |
| 192.0.2.30 | 3306/TCP | mysql        | MySQL 5.7.38                  |
| 192.0.2.30 | 8443/TCP | https        | nie ustalono                  |

Otwartych portów łącznie: 10, na 4 urządzeniach.

Łącznie stwierdzono 10 otwartych portów. Na 192.0.2.1 udostępniono usługi 53/TCP (dnsmasq 2.80), 80/TCP i 443/TCP (lighttpd 1.4.59). Na 192.0.2.10 działają 445/TCP (Samba smbd 4.15.13) oraz 5000/TCP (Synology DSM httpd). Na 192.0.2.20 otwarte są 23/TCP (telnet) i 554/TCP (rtsp). Na 192.0.2.30 dostępne są 22/TCP (OpenSSH 7.4), 3306/TCP (MySQL 5.7.38) oraz 8443/TCP (https).

Ryzyko wiąże się przede wszystkim z usługami przesyłającymi dane bez szyfrowania oraz z usługami bazodanowymi wystawionymi do sieci. Telnet na 192.0.2.20 i nieszyfrowany panel kamery na porcie 80 tego samego hosta pozwalają na przechwycenie poświadczeń. MySQL na 192.0.2.30 nasłuchuje w sieci, co w połączeniu z brakiem hasła konta root tworzy bezpośrednią ścieżkę do danych. Udostępnianie SMB na 192.0.2.10 oraz usługi zarządzające na 192.0.2.1 i 192.0.2.10 poszerzają powierzchnię ataku w segmencie.

## 5. Pogłębione testy podatności

Testy uruchamiane przeciwko znalezionym usługom. Ustalenie oznaczone jako wymagające uwagi to takie, które nie zakończyło się zwykłym „nic nie znaleziono”.

| URZĄDZENIE | TEST                 | USTALENIE                                                                                 |
|------------|----------------------|-------------------------------------------------------------------------------------------|
| 192.0.2.30 | ssl-poodle           | VULNERABLE:<br>SSL POODLE information leak<br>State: VULNERABLE<br>IDs: CVE:CVE-2014-3566 |
| 192.0.2.30 | http-slowloris-check | VULNERABLE:<br>Slowloris DOS attack<br>State: LIKELY VULNERABLE<br>IDs: CVE:CVE-2007-6750 |

Ustaień łącznie: **3**, w tym wymagających uwagi: **2**, pozostałe 1 zakończyło się wynikiem czystym.

### Bazy danych i aplikacje webowe

| WAGA      | GDZIE      | USTALENIE                                                                                                                                                                                                                                                                                                                                                                                                                |
|-----------|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Krytyczne | 192.0.2.30 | Potwierdzone zdalne wykonanie kodu na bazie danych (RCE)<br>Sonda wykonała polecenie systemowe przez usługę bazy danych.                                                                                                                                                                                                                                                                                                 |
| Wysokie   | 192.0.2.30 | Konto bazy danych bez hasła<br>root                                                                                                                                                                                                                                                                                                                                                                                      |
| Wysokie   | 192.0.2.30 | Dane wrażliwe dostępne w bazie danych<br>PESEL w crm.klienci; KARTA KREDYTOWA w crm.platnosci                                                                                                                                                                                                                                                                                                                            |
| Średnie   | 192.0.2.30 | Serwer WWW ujawnił ścieżki wymagające weryfikacji<br>Wykryte podczas fuzzingu katalogów; część może być fałszywa - wymaga ręcznego potwierdzenia. <a href="https://192.0.2.30:8443/.git/config">https://192.0.2.30:8443/.git/config</a> ,<br><a href="https://192.0.2.30:8443/backup.sql">https://192.0.2.30:8443/backup.sql</a> , <a href="https://192.0.2.30:8443/phpinfo.php">https://192.0.2.30:8443/phpinfo.php</a> |

Przeprowadzono pogłębione testy przeciwko znalezionym usługom; sformułowano 3 ustalenia, z czego 2 wymagają uwagi, a pozostały test zakończył się wynikiem czystym. Na 192.0.2.30 potwierdzono podatność SSL POODLE (CVE-2014-3566, stan VULNERABLE) — ujawnienie informacji w sesji szyfrowanej na porcie 8443. Na tym samym hoście test http-slowloris-check zwrócił stan LIKELY VULNERABLE dla ataku Slowloris (CVE-2007-6750), co grozi wyczerpaniem zasobów serwera WWW.

Ustalenia z warstwy bazodanowych dotyczą hosta 192.0.2.30. Stwierdzono potwierdzone zdalne wykonanie kodu na bazie PostgreSQL — sonda wykonała polecenie systemowe przez usługę bazy danych. Wykryto również konto MySQL bez hasła (root) oraz dostęp do danych wrażliwych w bazie: numer PESEL w crm.klienci i numer karty kredytowej w crm.platnosci.

Testy ekspozycji i poświadczeń nie wykazały podatności w następujących obszarach: anonimowe sesje i udziały SMB, skanowanie szablonami znanych podatności, domyślne poświadczenia oraz ryzyka infrastrukturalne — w tych zakresach stan jest prawidłowy.

## 6. Ekspozycja i poświadczenia

Udziały plików dostępne bez uwierzytelnienia, ruch przestarzałych mechanizmów rozwiązywania nazw, pozostawione domyślne dane logowania oraz informacje wyciekające z katalogu firmowego do klientów anonimowych.

| BADANY OBSZAR                            | WYNIK                                                                                         |
|------------------------------------------|-----------------------------------------------------------------------------------------------|
| Anonimowe sesje i udziały SMB            | stan prawidłowy — nie stwierdzono podatności                                                  |
| Zatrutowanie rozgłoszeń                  | brak danych<br>Sonda nie przekazała wyniku tego testu.                                        |
| Skanowanie szablonami znanych podatności | stan prawidłowy — nie stwierdzono podatności                                                  |
| Domyślne poświadczenia                   | stan prawidłowy — nie stwierdzono podatności                                                  |
| Wycieki z katalogu LDAP                  | test nie wykonał się<br>Test nie został uruchomiony, więc ten obszar pozostaje niesprawdzony. |
| Ryzyka infrastrukturalne                 | stan prawidłowy — nie stwierdzono podatności                                                  |

Jeden moduł badania nie wykonał się poprawnie. Wyniku tych testów nie należy czytać jako „nic nie znaleziono” - one się nie odbyły.

W zakresie ekspozycji i poświadczeń nie stwierdzono podatności dla anonimowych sesji i udziałów SMB, skanowania szablonami znanych podatności, domyślnych poświadczeń oraz ryzyk infrastrukturalnych — stan prawidłowy.

Testy zatrutowania rozgłoszeń nie dostarczyły wyniku: sonda nie przekazała danych, dlatego obszar ten pozostaje niesprawdzony. Test wycieków z katalogu LDAP nie wykonał się. Żadnego z tych dwóch obszarów nie traktuje się jako zweryfikowanego; brak wyniku nie jest równoznaczny z brakiem podatności.

## 7. Protokoły przemysłowe ICS i OT

Punkty końcowe sterowania przemysłowego, takie jak CODESYS Runtime, EtherNet/IP czy IEC 60870-5-104, które zwykle nie mają czego szukać w sieci biurowej.

| URZĄDZENIE | PORT    | PROTOKÓŁ | STAN | OCENA SONDY |
|------------|---------|----------|------|-------------|
| 192.0.2.30 | 502/TCP | Modbus   | open | WARNING     |

Punktów końcowych ICS/OT: 1. Stan open|filtered oznacza, że sonda nie mogła rozstrzygnąć, czy port jest otwarty, czy odfiltrowany.

W sieci zidentyfikowano 1 punkt końcowy ICS/OT: usługę Modbus na 192.0.2.30, port 502/TCP, stan open, ocena sondy — WARNING. Protokoły przemysłowe nie zapewniają uwierzytelniania ani integralności, a ich obecność na hoście ogólnego przeznaczenia, na którym stwierdzono jednocześnie podatności krytyczne, poszerza powierzchnię ataku o segment automatyki.

Usługa ta nie powinna być eksponowana poza wydzielonym segmentem OT. Host 192.0.2.30 pełni rolę serwera ogólnego (CentOS 7) i łączy w sobie rolę punktu końcowego ICS/OT z usługami bazodanowymi i WWW, co nie odpowiada wymaganiom separacji.

## 8. Diagnostyka sieci

Kondycja i konfiguracja sieci: opóźnienia, DNS, podatności na podsłuch i podszywanie się, zabezpieczenie portu dostępowego, ruch wychodzący oraz przepustowość. Poniżej znajdują się wyłącznie te testy, których wynik sonda przekazała.

### Opóźnienia w sieci

|           |        |
|-----------|--------|
| Status    | ok     |
| Najniższe | 0.4 ms |
| Średnie   | 0.8 ms |
| Najwyższe | 1.9 ms |

### Kondycja DNS

|                 |           |
|-----------------|-----------|
| Status          | ok        |
| Odpytany serwer | 192.0.2.1 |
| Czas odpowiedzi | 12 ms     |

### Podatność na podsłuch (MITM)

|                                                                              |                                                                               |
|------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| Status                                                                       | ok                                                                            |
| ▲ Brak blokady Gratuitous ARP — ruch w sieci można przechwycić i podsłuchać. |                                                                               |
| Assessment                                                                   | Przełącznik nie blokuje Gratuitous ARP - ruch w segmencie można przekierować. |

### Filtrowanie ruchu wychodzącego

|                                 |                 |
|---------------------------------|-----------------|
| Status                          | ok              |
| Porty przepuszczane na zewnątrz | ▲ 23, 445, 3389 |

### Bezpieczeństwo sieci bezprzewodowej

|                                                                     |               |
|---------------------------------------------------------------------|---------------|
| Status                                                              | blocked       |
| Reason                                                              | foreign_block |
| ▲ Nie udało się włączyć trybu monitora, więc nasłuch się nie odbył. |               |
| Przechwycone ramki EAPOL                                            | 0             |

### Przepustowość łącza

|                   |              |
|-------------------|--------------|
| Opóźnienie (ping) | 18.4 ms      |
| Pobieranie        | 184.2 Mbit/s |
| Wysyłanie         | 41.7 Mbit/s  |

Najbardziej obciążające urządzenia

| ADRES      | PAKIETY | RUCH ŁĄCZNIE | WYSŁANE            | ODEBRANE           |
|------------|---------|--------------|--------------------|--------------------|
| 192.0.2.10 | 182340  | 136,3 MB     | 90000 pk · 76,3 MB | 92340 pk · 60,0 MB |
| 192.0.2.1  | 90120   | 17,5 MB      | 45000 pk · 8,6 MB  | 45120 pk · 9,0 MB  |

Kondycja sieci w warstwie podstawowej nie budzi zastrzeżeń. Opóźnienia w sieci utrzymują się na niskim poziomie (0,4 ms minimalne, 0,8 ms średnie, 1,9 ms maksymalne), a kondycja DNS jest prawidłowa — odpytany serwer 192.0.2.1 odpowiada w czasie 12 ms. Przepustowość łącza wynosi 184,2 Mbit/s w kierunku pobierania i 41,7 Mbit/s w kierunku wysyłania przy opóźnieniu ping 18,4 ms. Największe obciążenie generują 192.0.2.10 (182340 pakietów, 136,3 MB) oraz 192.0.2.1 (90120 pakietów, 17,5 MB).

W konfiguracji warstwy drugiej i kontroli ruchu wychodzącego stwierdzono istotne słabości. Przełącznik nie blokuje Gratuitous ARP, wobec czego ruch w segmencie można przekierować i podsłuchać. Filtrowanie ruchu wychodzącego przepuszcza na zewnątrz porty 23, 445 i 3389. Testy bezpieczeństwa sieci bezprzewodowej nie odbyły się — nie udało się włączyć trybu monitora (przyczyna: foreign\_block), w związku z czym nie przechwycono żadnych ramek EAPOL i nasłuch nie został wykonany.

## 9. Plan naprawy

Działania wynikające wyłącznie z ustaleń tego badania, uszeregowane od najpilniejszego.

1. Zamknięcie podatności zdalnego wykonania kodu w PostgreSQL na 192.0.2.30.
2. Wyłączenie obsługi SSLv3 i usunięcie podatności SSL POODLE na 192.0.2.30, port 8443.
3. Ustawienie hasła dla konta root bazy MySQL na 192.0.2.30 i ograniczenie dostępu do danych wrażliwych w crm.klienci oraz crm.platnosci.
4. Wdrożenie ochrony przed atakiem Slowloris na 192.0.2.30, port 8443.
5. Wyłączenie usługi Telnet na 192.0.2.20, port 23/TCP, i zastąpienie jej protokołem szyfrowanym.
6. Włączenie blokady Gratuitous ARP na przełączniku w segmencie.
7. Wymuszenie HTTPS i ograniczenie dostępu do panelu kamery na 192.0.2.20, port 80.
8. Ograniczenie dostępu do usługi MySQL na 192.0.2.30, port 3306/TCP, do sieci zarządzającej.
9. Ograniczenie dostępu do udostępniania SMB na 192.0.2.10, port 445/TCP.
10. Aktualizacja dnsmasq na 192.0.2.1 w związku z podatnościami CVE-2021-3448, CVE-2020-25681, CVE-2020-25684.
11. Weryfikacja i usunięcie eksponowanych ścieżek .git/config, backup.sql oraz phpinfo.php na 192.0.2.30.
12. Wdrożenie egress filtering z zablokowaniem portów 23, 445 i 3389 w ruchu wychodzącym.
13. Izolacja usługi Modbus na 192.0.2.30, port 502/TCP, w wydzielonym segmencie OT.
14. Zdiagnozowanie przyczyny nieudanego skanowania portów na 192.0.2.40.
15. Uruchomienie testu wycieków z katalogu LDAP, testu zatruwania rozgłoszeń oraz testów bezpieczeństwa sieci bezprzewodowej z uwzględnieniem trybu monitora.

Ponowne przeprowadzenie audytu weryfikującego przy pomocy sprzętowego analizatora w celu technicznego potwierdzenia skuteczności wdrożonych zabezpieczeń.